🔐 Web Application Security Assessment Report

📌 1. Executive Summary

This report presents the findings of a security assessment conducted on a live web application focusing on Cross-Site Scripting (XSS) vulnerabilities. The testing was performed in an authorized environment to evaluate the application's input handling and security posture.

🎯 2. Objective

To identify potential XSS vulnerabilities (Reflected, Stored, and DOM-based) in the application and evaluate the effectiveness of input validation mechanisms.

📍 3. Scope

- Target: Live Web Application (Authorized Testing)
- Tested Module: Contact Form Page
- Input Fields:
  - Full Name
  - Email Address
  - Phone Number
  - Message Field

🛠 4. Tools Used

- Web Browser (Google Chrome)
- Browser Developer Tools
- Manual Payload Testing

🔍 5. Testing Methodology

The following approach was used:

1. Input Field Identification
2. Payload Injection
3. Response Analysis

4. Validation of Execution

⚠□ 6. Vulnerability Testing

◈ 6.1 Reflected XSS

Payload Used:

```
<script>alert(1)</script>
```

Result:

- Input was not reflected in the response
- No script execution observed

◈ 6.2 Alternate Payload Testing

```
<img src=x onerror=alert(1)>
```

Result:

- No execution observed
- Application handled input securely

◈ 6.3 Stored XSS

Payload Used:

```
<script>alert('stored')</script>
```

Result:

- Input may be stored but not executed
- No stored XSS vulnerability found

◈ 6.4 DOM-Based XSS

Payload Used (URL):

```
#<script>alert(1)</script>
```

Result:

- No DOM-based execution observed

📊 7. Observations

- Input fields validate user input effectively
- Script payloads are not executed
- No reflection of malicious input in response
- Application demonstrates secure input handling

✅ 8. Conclusion

The application is not vulnerable to basic XSS attacks in the tested areas. Proper input validation and output handling mechanisms are implemented, reducing the risk of script execution.

🛡 9. Recommendations

- Implement output encoding techniques
- Apply strict input validation
- Use Content Security Policy (CSP)
- Perform regular security assessments

📚 10. Learning Outcome

This assessment provided practical experience in testing real-world applications and understanding how secure coding practices prevent XSS vulnerabilities.

⚖️ 11. Ethical Consideration

Testing was conducted with proper authorization. No harmful or intrusive actions were performed during the assessment.